Leash · MLH Solana Hackathon · AI Track

Prompts can be hijacked. This limit can’t.

Spending limits for AI agents, enforced by a Solana program.

The problem

An agent that can pay can be tricked into paying.

Guardrails in a prompt

They live inside the system being attacked. One poisoned page or API response can talk around them.

A key in a hot wallet

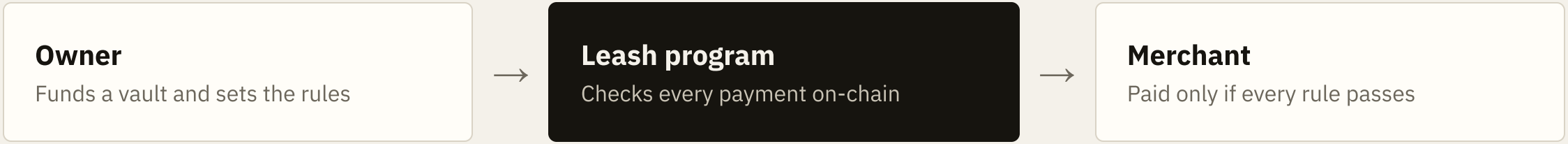
All or nothing. Whoever controls the agent controls the whole balance.

Approve every payment

Safe, but it stops being an agent. Nobody wants to tap approve on a tenth of a cent.

The idea

Move the rules out of the model and into the chain.



The agent’s key can ask. It can’t change a rule, reach the vault directly, or pay anyone off the list.

What is enforced

Five rules no prompt can reach.

Allowlist	Only approved merchants	`MerchantNotAllowed`
Per-payment cap	Stops inflated invoices	`OverPaymentCap`
Daily budget	Limits the worst day, even if the server is breached	`OverDailyCap`
Expiry	Authority ends by default	`PolicyExpired`
Kill switch	Owner pauses from their own key	`PolicyPaused`

The live demo

Same attack, same agent, two wallets.

LEASH POLICY

20 dUSD to attacker

MerchantNotAllowed

REFUSED

PLAIN HOT WALLET

20 dUSD to attacker

Transfer confirmed

STOLEN

Judges can write their own attack. No wallet or install, and every result links to the public record.

Why Solana

This only works where a payment costs almost nothing.

Per-request pricing

An agent can buy a single API call for cents. Network fees are a tiny fraction of that.

Speed

A payment confirms in the middle of the agent’s task, so it can pay and continue in one flow.

Public proof

Allowed and refused attempts both land on-chain. Anyone can audit an agent’s spending.

AI and Solana each do real work

The model decides. The chain limits the damage.

AI

A Gemini agent takes a goal, decides which data is worth buying, pays over HTTP 402, and writes the result.

Solana

An Anchor program holds the funds and applies the rules. It records a hash of the agent’s stated reason with each payment.

Shipped this weekend, and next

Working on devnet today.

Built

Deployed program, unit-tested policy logic, paid APIs, Gemini agent, and a public attack demo.

Next

A security audit before mainnet, real USDC, an SDK for agent frameworks, and rules per task.

Try the demo · Source · Program on devnet